

Индивидуальный проект
Тестирование веб-приложений на примере Damn Vulnerable
Web Application (DVWA)
Этап 5 - Использование Burp Suite

Дисциплина: Информационная безопасность

Студент: Оганисян Гор Акаикович

Группа: НБИбд-01-24

Дата выполнения: 14.05.2026

1. Цель работы

Изучить назначение и базовые возможности инструмента Burp Suite в условиях учебной лаборатории, а также получить практические навыки перехвата и анализа HTTP-трафика между браузером и веб-приложением DVWA с целью выявления типовых уязвимостей.

2. Введение

Burp Suite — это интегрированная платформа для тестирования безопасности веб-приложений, разработанная компанией PortSwigger. Инструмент позиционируется как профессиональный набор средств для поиска уязвимостей и широко применяется специалистами по информационной безопасности при проведении пентестов.

Burp Suite представляет собой набор мощных инструментов безопасности веб-приложений, которые демонстрируют реальные возможности злоумышленника, проникающего в веб-приложения. Платформа включает прокси-сервер для перехвата трафика, сканер уязвимостей, инструмент для ручного изменения запросов, модуль перебора параметров и многое другое.

В рамках дисциплины по информационной безопасности Burp Suite рассматривается исключительно как учебный инструмент аудита. Его применение допустимо только на собственном учебном стенде, локальной виртуальной машине с DVWA или другой системе, где у студента есть прямое разрешение на тестирование.

Главная цель работы заключается не во взломе реального приложения, а в понимании того, как специалист по безопасности анализирует HTTP-трафик, выявляет небезопасные параметры запросов и формулирует рекомендации по защите.

3. Требования и предварительная подготовка

Для выполнения этапа рекомендуется подготовить:

- Kali Linux или другой дистрибутив Linux с установленным Burp Suite Community Edition;
- браузер, настроенный для работы через прокси Burp Suite (как правило, Firefox с расширением FoxyProxy);
- локальный учебный веб-сервер с DVWA или аналогичным тестовым приложением;
- известный адрес тестовой машины, например <http://192.168.56.101/DVWA/>;
- доступность веб-сервера по HTTP или HTTPS;
- разрешение на проведение проверки, если стенд не принадлежит студенту;
- папку для сохранения результатов работы.

Перед запуском необходимо убедиться, что тестирование выполняется в изолированной лабораторной среде. Использование Burp Suite против чужих сайтов, публичных IP-адресов и реальных производственных систем без разрешения недопустимо.

4. Назначение Burp Suite и общий принцип работы

Burp Suite работает как промежуточный прокси-сервер между браузером пользователя и целевым веб-приложением. Весь HTTP/HTTPS-трафик проходит через Burp, что позволяет перехватывать, просматривать, изменять и повторно отправлять запросы и ответы.

Основные компоненты Burp Suite Community Edition:

- Proxy — перехват и просмотр HTTP/HTTPS-запросов и ответов в режиме реального времени. Позволяет изменять данные до их отправки на сервер или возврата браузеру.
- Repeater — инструмент для ручного повторения отдельных HTTP-запросов с изменёнными параметрами. Удобен для ручной проверки конкретных точек входа.

- Intruder — модуль автоматизированного перебора значений параметров запроса. Применяется для проверки устойчивости к атакам на аутентификацию и параметры форм.
- Decoder — утилита для кодирования и декодирования данных в форматах Base64, URL, HTML, HEX и других.
- Comparer — инструмент сравнения двух HTTP-запросов или ответов для выявления различий.
- Logger — журнал всех HTTP-запросов, прошедших через прокси.

5. Пошаговое использование в учебной среде

Ниже приведён безопасный пример для локального учебного стенда DVWA, размещённого в виртуальной сети. В качестве адреса тестовой машины используется 192.168.56.101, веб-сервер работает на порту 80, а приложение доступно по пути /DVWA/.

Пример исходных условий учебного стенда:

- адрес тестовой машины: 192.168.56.101;
- протокол: HTTP;
- порт: 80;
- путь к учебному приложению: /DVWA/;
- уровень безопасности DVWA: Low;
- цель проверки: перехват HTTP-трафика и анализ параметров форм.

Шаг 1. Запуск Burp Suite и настройка прокси.

Burp Suite запускается через меню приложений Kali Linux или из терминала. После запуска выбирается вариант Temporary project с настройками по умолчанию.

Настройка прокси в браузере Firefox:

- открыть Настройки > Параметры сети > Ручная настройка прокси;
- HTTP-прокси: 127.0.0.1, Порт: 8080;
- установить флажок «Использовать этот прокси-сервер для всех протоколов».

Проверка, что прокси активен в Burp Suite:

Вкладка Proxy > Intercept > кнопка Intercept is on

Шаг 2. Установка сертификата Burp Suite для HTTPS.

Для перехвата HTTPS-трафика необходимо установить сертификат Burp Suite в браузер. В строке адреса Firefox ввести:

`http://burpsuite`

На открывшейся странице нажать «CA Certificate» и сохранить файл. Затем импортировать сертификат в Firefox: Настройки > Конфиденциальность и защита > Сертификаты > Импортировать.

Шаг 3. Перехват запроса аутентификации DVWA.

В браузере открыть страницу входа в DVWA:

`http://192.168.56.101/DVWA/login.php`

Ввести стандартные учётные данные (admin / password) и нажать кнопку Login. В Burp Suite на вкладке Proxy > Intercept появится перехваченный POST-запрос. Пример перехваченного запроса:

```
POST /DVWA/login.php HTTP/1.1
Host: 192.168.56.101
```

Content-Type: application/x-www-form-urlencoded

username=admin&password=password&Login=Login

Запрос можно изучить, изменить параметры и отправить на сервер кнопкой Forward, либо отклонить кнопкой Drop.

Шаг 4. Отправка запроса в Repeater для ручного тестирования.

Перехваченный запрос передаётся в модуль Repeater: правый клик по запросу > Send to Repeater. На вкладке Repeater запрос можно изменить и отправить повторно кнопкой Send, наблюдая ответ сервера в правой панели. Это позволяет вручную проверять различные значения параметров без повторной работы с браузером.

Шаг 5. Использование Intruder для перебора паролей (учебная демонстрация).

Перехваченный запрос передаётся в Intruder: правый клик > Send to Intruder. На вкладке Positions выделяется значение параметра password как позиция подстановки. На вкладке Payloads загружается небольшой список паролей. Запуск выполняется кнопкой Start Attack. По длине ответа или коду статуса можно определить, при каком значении сервер вернул иной результат.

Пример команды для настройки Intruder в Community Edition:

Attack type: Sniper

Payload type: Simple list

Payloads: password, 123456, admin, letmein, dvwa

Шаг 6. Анализ HTTP-заголовков ответа.

На вкладке Proxy > HTTP History отображается история всех запросов. Для каждого запроса можно изучить заголовки ответа сервера во вкладке Response > Headers. Следует обратить внимание на наличие или отсутствие защитных заголовков:

- X-Frame-Options — защита от кликджекинга;
- X-Content-Type-Options — запрет MIME-сниффинга;
- Content-Security-Policy — политика безопасности содержимого;
- Strict-Transport-Security — принудительное использование HTTPS;
- Set-Cookie с атрибутами HttpOnly и Secure.

Шаг 7. Сохранение результатов работы.

История запросов сохраняется через меню:

Proxy > HTTP History > правый клик > Save selected items

Проект целиком может быть сохранён через:

Burp > Save copy of project > выбрать папку

6. Пример анализа результата

После завершения работы с Burp Suite необходимо проанализировать историю перехваченных запросов и сформулировать выводы. В учебной среде DVWA типичные наблюдения включают следующее.

Аутентификация и управление сессией:

- учётные данные передаются в теле POST-запроса в открытом виде без дополнительного шифрования на уровне приложения;
- идентификатор сессии (PHPSESSID) передаётся в cookie без атрибута Secure, что допускает его передачу по незащищённому каналу;

- cookie сессии не имеет атрибута HttpOnly, что теоретически позволяет получить его через XSS.

Заголовки ответа сервера:

- сервер раскрывает информацию о версии Apache и PHP в заголовке Server;
- отсутствуют заголовки X-Frame-Options, X-Content-Type-Options и Content-Security-Policy;
- соединение не использует HTTPS, поэтому заголовок Strict-Transport-Security также отсутствует.

Параметры форм:

- параметры форм не содержат CSRF-токенов на уровне Low в DVWA;
- значения параметров не проходят валидацию на стороне сервера, что открывает возможность для инъекций при уровне безопасности Low.

При анализе результата важно не считать каждое наблюдение готовой уязвимостью. Часть замечаний требует проверки контекста: например, отсутствие заголовка безопасности в учебном приложении является намеренным, чтобы продемонстрировать соответствующие атаки.

7. Практические рекомендации по защите

По итогам проверки рекомендуется:

- передавать учётные данные только по защищённому каналу HTTPS;
- устанавливать атрибуты HttpOnly и Secure для cookie сессий;
- добавить защитные HTTP-заголовки: X-Frame-Options, X-Content-Type-Options, Content-Security-Policy, Strict-Transport-Security;
- скрывать сведения о версии веб-сервера и интерпретатора в заголовке Server;
- реализовать защиту от CSRF с помощью уникальных токенов для каждой формы;
- выполнять валидацию и санитизацию всех входных данных на стороне сервера;
- использовать политику минимально необходимых привилегий для учётных записей приложения;
- периодически проверять конфигурацию приложения после внесения изменений.

8. Частые ошибки при использовании Burp Suite

- тестирование выполняется не в лабораторной среде и без разрешения владельца ресурса;
- браузер не настроен для работы через прокси Burp Suite, из-за чего трафик не перехватывается;
- сертификат Burp Suite не импортирован в браузер, что приводит к ошибке SSL при открытии HTTPS-страниц;
- режим Intercept не активирован, вследствие чего запросы проходят мимо панели перехвата;
- перепутаны HTTP и HTTPS при указании адреса цели;
- результаты Intruder воспринимаются как окончательное доказательство уязвимости без ручной проверки;
- не сохраняются результаты работы, из-за чего сложно подтвердить проделанную работу;
- в Community Edition не учитывается ограничение скорости Intruder, что делает перебор медленным.

9. Безопасность и правовые аспекты

Burp Suite является инструментом двойного назначения. Он полезен для обучения и профессионального аудита безопасности, но его нельзя применять против чужих веб-приложений и серверов без письменного разрешения владельца.

В рамках данного проекта все действия должны выполняться только на DVWA, локальной виртуальной машине или другом специально подготовленном учебном стенде. Нельзя использовать результаты перехвата трафика для несанкционированного доступа, изменения данных, обхода защиты или нарушения работы сервера.

Правильное использование Burp Suite предполагает ответственное отношение: сначала получить разрешение, затем выполнить проверку, зафиксировать результат и предложить меры защиты.

10. Заключение

В ходе выполнения этапа студент знакомится с назначением Burp Suite и получает представление о том, как специалист по безопасности анализирует HTTP-трафик веб-приложения. На примере учебного стенда DVWA рассматривается перехват запросов, ручное изменение параметров в Repeater, базовый перебор в Intruder и анализ HTTP-заголовков ответа.

Практическая ценность работы состоит в том, что студент учится понимать структуру HTTP-взаимодействия между браузером и сервером, видеть небезопасные параметры конфигурации и формулировать рекомендации по их устранению. Burp Suite не заменяет полноценный аудит безопасности, однако является одним из наиболее востребованных инструментов при проведении тестирования на проникновение.

11. Источники и литература

1. Burp Suite — официальная документация PortSwigger Web Security.
2. Документация Kali Linux.
3. DVWA — учебное веб-приложение для практики по информационной безопасности.
4. PortSwigger Web Security Academy — бесплатные учебные материалы по уязвимостям веб-приложений.
5. Материалы по защитным HTTP-заголовкам и базовому аудиту веб-приложений.